Intelligent Phishing, Web Security, PKI Validation & CTI Platform

Complete Backend Component Specification, Microservice Topology, PKI Trust Engine & Platform Security Hardening

1. Executive Overview & Architectural Scope

Modern web threats exploit multiple layers of the internet trust stack simultaneously—combining visually deceptive credential-harvesting portals, application-level misconfigurations, and compromised or weakly generated Public Key Infrastructure (PKI) trust chains. The October 2026 eMudhra TLS intermediate certificate compromise demonstrated how weak key generation during a Certificate Authority (CA) key ceremony can undermine HTTPS identity assurances across global root stores (Banbreach Incident Analysis).

To address these converging threats in a single platform, the backend architecture integrates four core detection pillars—**Intelligent Phishing Detection**, **Cryptographic PKI & Certificate Validation**, **Application-Level Web Security Assessment**, and **Collaborative Threat Intelligence (CTI)**—paired with strict microVM isolation and anti-SSRF security controls to protect the scanning platform itself.

2. Dual-Lane Backend Orchestration & Core Infrastructure Components

Because browser extensions and email gateways require sub-150ms block/allow verdicts while full headless browser detonation and cryptographic chain verification require several seconds, the backend routes every incoming URL through a **Dual-Lane Execution Pipeline** before synthesizing a final composite risk score:

- **Fast-Path Synchronous Lane (<150 ms):** Canonicalizes incoming URLs (resolving Punycode/IDN homographs and stripping tracking parameters) and queries in-memory Redis Bloom/Cuckoo filters, cached domain verdicts, Google Safe Browsing API v4 hash prefixes, and active browser certificate revocation lists such as Mozilla OneCRL.
- **Deep-Scan Asynchronous Lane (2–15 s):** Publishes uncached or suspicious URLs to Apache Kafka topics consumed concurrently by four isolated worker pools (Phishing & DOM Detonation, PKI & CT Log Validation, Application Security Auditing, and CTI Graph Correlation), streaming live status updates back to clients over WebSockets or signed webhooks.
- **Composite Risk Aggregator & Verdict Engine:** Combines multi-pillar telemetry into a weighted 0–100 risk score, deterministic classification (`CLEAN`, `SUSPICIOUS`, `MALICIOUS`, or `PKI_TRUST_COMPROMISED`), explainable analyst reason codes, and standardized STIX 2.1 indicator bundles.

Infrastructure Component	Backend Responsibility & Data Flow	Recommended Stack & Standards
API Gateway & URL Canonicalizer	Terminates TLS, enforces tenant rate limits, normalizes URLs (IDN/Punycode decoding), and dispatches synchronous or asynchronous scan jobs.	Envoy / NGINX, Go or Rust API Gateway, RFC 9083 (RDAP)
Event Streaming Broker	Buffers high-volume Certificate Transparency streams and distributes URL scan tasks across worker pools with dead-letter retry queues.	Apache Kafka or RabbitMQ with Protobuf schema validation
Relational & Vector Store	Persists structured scan reports, RBAC policies, X.509 certificate metadata, and perceptual/DOM vector embeddings for visual brand matching.	PostgreSQL 16+ with `pgvector` and RFC 5280 schema
Threat Graph Database	Models multi-hop links across domains, IP/ASN blocks, TLS certificate SHA-256 fingerprints, JA4 hashes, and threat actor infrastructure.	Neo4j or JanusGraph implementing STIX 2.1 SDOs and SROs
Hot Cache & Bloom Tier	Serves sub-millisecond lookups for known malicious URLs, active CRLs, cached OCSP responses, and API authentication tokens.	Redis Cluster with probabilistic Bloom filters (Abuse.ch URLhaus)
Encrypted Artifact Vault	Stores defanged HTML DOM snapshots, full-page PNG screenshots, HTTP HAR network traces, and raw X.509 PEM certificate chains.	S3-compatible object storage with KMS envelope encryption

3. Pillar 1: Intelligent Phishing & Malicious Website Detection Components

To detect zero-day phishing portals impersonating online banking, recruitment platforms, universities, government portals, and digital payment links, Pillar 1 combines four specialized analysis microservices:

- **Lexical, IDN & Domain Reconnaissance Worker:** Computes Levenshtein edit distance, Jaro-Winkler similarity, and token combosquatting against protected brand keywords; detects mixed-script Unicode/Punycode homographs (`xn--`); queries domain registration timestamps via RFC 9083 (RDAP) to flag Newly Registered Domains (NRDs < 30 days old); and inspects DNS A/AAAA/MX/TXT records for fast-flux TTL anomalies.
- **Headless Browser Detonation Worker:** Renders target URLs inside an instrumented Playwright headless browser instance to traverse client-side redirect chains (HTTP `301`/`302`, HTML `meta refresh`, JavaScript `window.location`), intercept `fetch` and `XMLHttpRequest` payloads to uncover credential exfiltration servers, and defeat anti-bot cloaking via residential egress proxies and realistic browser TLS fingerprints (Browserless TLS Fingerprinting Guide).

- **DOM & Credential-Harvesting Heuristics Engine:** Parses the live rendered DOM tree to identify password inputs (`input[type="password"]`), payment card fields, and OTP forms submitting to cross-origin domains; flags fake Browser-in-the-Browser (BitB) OAuth windows, hidden iframes, and DevTools/right-click blockers; and scans deobfuscated JavaScript bundles using YARA rules for known phishing kits.
- **Computer Vision & Brand Impersonation Pipeline:** Captures full-page screenshots and MurmurHash3 favicon hashes; runs object detection to isolate brand logos; and compares perceptual hashes (pHash/dHash) and vision embeddings against verified corporate templates—triggering a critical phishing alert whenever visual similarity exceeds threshold while the registrable domain is unauthorized.

4. Pillar 2: Cryptographic Trust, PKI & Certificate Validation Components

Standard browsers only verify that a certificate chains to a trusted root and has not expired. However, in the October 2026 eMudhra certificate incident, researchers discovered that eight intermediate CA certificates (six TLS and two code-signing) were generated with recoverable ECDSA P-384 private keys whose scalar values fell below 256 due to a faulty key ceremony script (Banbreach Incident Analysis). Moreover, invalid Certificate Revocation List (CRL) signatures from those same six TLS intermediates had surfaced 16 months earlier in June 2025 (Shieldworkz PKI Analysis). Pillar 2 implements five deep PKI validation components to catch cryptographic and CA governance failures:

- **Cryptographic Key-Entropy & Parameter Auditor:** Inspects every leaf, intermediate, and root certificate in the presented chain to enforce minimum key sizes (RSA ≥ 2048-bit, ECDSA ≥ P-256, SHA-256+ signatures); runs Fermat's factorization, small-prime GCD checks, and ROCA vulnerability tests on RSA moduli; verifies ECDSA public key points lie on the specified curve without small-subgroup weaknesses; and flags any certificate chained to CAs with known RNG or key-ceremony flaws (Help Net Security Report).
- **Multi-Store Path & Cross-Sign Validator:** Executes strict RFC 5280 certification path validation across Mozilla NSS, Google Chrome Root Program, Apple, Microsoft, and Oracle Java trust stores simultaneously; validates `basicConstraints` (`cA` boolean and `pathLenConstraint`), `keyUsage`, `extendedKeyUsage`, and `nameConstraints`; and traces cross-signed intermediate paths to detect distrusted CAs still chaining to an alternate active root (Banbreach Incident Analysis).
- **Certificate Transparency (CT) Log Stream Ingestor:** Connects continuously to public Certificate Transparency logs via RFC 6962 and RFC 9162 (CT v2.0) tile and stream APIs; verifies Signed Certificate Timestamps (SCTs) delivered via X.509 extensions, TLS handshake extensions, or OCSP stapling; validates Merkle audit paths against Signed Tree Heads (STHs); and alerts domain owners in real time when unexpected CAs issue certificates for their brand or typosquatted domains.
- **Multi-Channel Revocation & CA Health Monitor:** Queries live RFC 6960 (OCSP) responders and checks OCSP Stapling (`status_request` / `Must-Staple`); downloads and cryptographically validates full and delta CRLs—treating invalid CRL signatures or expired `nextUpdate` fields as early indicators of CA key-management compromise (Shieldworkz PKI Analysis)—and synchronizes browser push-revocation feeds (Mozilla OneCRL, Chrome CRLSets, Apple Valid).

- **DNS CAA & DV Hijack Correlation Engine:** Queries RFC 8659 (DNS CAA) `issue` and `issuewild` resource records across the domain hierarchy and compares them against the issuing CA of the active TLS certificate, flagging unauthorized CA issuance or potential BGP/DNS hijacks (Cisco Talos Blog).

PKI Sub-Component	Cryptographic & Policy Verification	Targeted Threat Scenario	Standard / Spec
Key-Entropy & Curve Auditor	Audits RSA/ECDSA key lengths, small prime factors, curve point validity, and weak CA intermediate lineage.	Recoverable CA or leaf keys from faulty RNG/key ceremonies (eMudhra Incident).	RFC 5280
Multi-Store Chain Verifier	Validates X.509 path constraints and cross-signatures across NSS, Chrome, Apple, MS, and Java stores.	Cross-signed intermediates bypassing single-vendor root distrust (Help Net Security).	RFC 6818
CT Log & SCT Verifier	Validates embedded SCTs, Merkle inclusion proofs, and monitors global CT streams for lookalike domains.	Unlogged or rogue certificates issued by compromised intermediates (Cloudflare Blog).	RFC 9162 (CT 2.0)
Revocation & CRL Monitor	Verifies OCSP, OCSP Stapling, CRL cryptographic signatures, and OneCRL/CRLSet inclusion.	Revoked intermediate usage and early CA key-ceremony anomalies (Shieldworkz).	RFC 6960 (OCSP)
DNS CAA Policy Checker	Compares active certificate issuer against authoritative DNS CAA records (`issue`, `issuewild`).	Fraudulent DV issuance via unauthorized CAs or DNS hijacking (CaptainDNS Guide).	RFC 8659 (CAA)

5. Pillar 3: Application-Level Web Security Assessment Components

Legitimate websites with weak application security can be hijacked to host phishing kits or leak user credentials, while malicious sites frequently exhibit telltale server and TLS fingerprints. Pillar 3 performs safe, non-destructive web security assessments:

- **HTTP Security Header Auditor:** Evaluates HTTP response headers against the OWASP Secure Headers Project baseline, parsing Content-Security-Policy (CSP) for unsafe directives (`unsafe-inline`, `unsafe-eval`, wildcard origins), verifying Strict-Transport-Security (HSTS) `max-age` and

`preload` directives, and checking `X-Frame-Options`, `X-Content-Type-Options: nosniff`, `Referrer-Policy`, and `Permissions-Policy`.

- **Session Cookie & CORS Inspector:** Audits `Set-Cookie` headers on login and payment flows for missing `Secure`, `HttpOnly`, and `SameSite=Strict|Lax` flags, and inspects `Access-Control-Allow-Origin` reflection to flag overly permissive CORS policies.
- **TLS Protocol, Cipher & JA4S Fingerprint Scanner:** Probes supported TLS versions (flagging deprecated SSLv3, TLS 1.0, and TLS 1.1), identifies weak or non-forward-secret ciphers (RC4, 3DES, NULL, static RSA), and computes server JA3S and JA4+ TLS fingerprints to detect AiTM reverse-proxy phishing toolkits (such as Evilginx2) and C2 frameworks (Cloudflare JA4 Docs).
- **Passive Exposure & Outdated Component Matcher:** Extracts server banners (`Server`, `X-Powered-By`), client-side JavaScript library versions, and non-intrusive exposure checks (`/.env`, `/.git/HEAD`, `/security.txt`) to map exposed services and vulnerable software dependencies against known CVE advisories.

6. Pillar 4: Collaborative Threat Intelligence (CTI) & Reputation Components

To transform isolated detections into real-time collective defense across organizations, CERTs, and security researchers, Pillar 4 implements standardized intelligence federation and crowdsourced reputation scoring:

- **Bi-Directional STIX 2.1 & TAXII 2.1 Federation Server:** Implements an OASIS-compliant TAXII 2.1 REST API server and client connector to publish and ingest STIX 2.1 Domain Objects (`Indicator`, `Malware`, `Infrastructure`, `Sighting`) and Cyber-Observable Objects (`url`, `domain-name`, `x509-certificate`), with native synchronization for enterprise MISP instances (NHIMG STIX/TAXII Guide).
- **External Threat Feed Aggregator & Normalizer:** Continuously ingests, deduplicates, and normalizes indicators from Google Safe Browsing, Abuse.ch URLhaus, PhishTank, and national CERT feeds while preserving Traffic Light Protocol (TLP) handling markings and immutable object versioning (`id` + `modified` timestamp).
- **Crowdsourced Consensus & Reputation Decay Engine:** Assigns dynamic reliability weights to community reporters based on historical precision, requires automated sandbox verification or multi-organization sighting consensus before promoting a user-submitted URL to global blocklists, and applies exponential time-decay curves so remediated legitimate domains recover their reputation score once cleaned.

7. Mandatory Platform Security Features (Hardening the Scanner Backend)

Because the platform actively fetches, renders, and parses hostile websites and malformed certificates crafted by attackers, the backend itself is a high-value target for Server-Side Request

Forgery (SSRF), browser sandbox escape, parser buffer overflows, and analyst XSS. The table below specifies the mandatory defensive controls required to secure the platform:

Platform Threat Vector	Mandatory Backend Security Control & Implementation	Reference Standard / Guide
Headless Browser RCE & Escape	Run every Playwright browser detonation inside a single-use AWS Firecracker microVM or gVisor (`runsc`) sandbox with a read-only rootfs, seccomp-bpf syscall filters, and immediate VM destruction after a 15-second hard timeout.	Firecracker vs. gVisor Isolation Guide
SSRF & DNS Rebinding	Place scanner egress in an isolated untrusted VPC with a custom DNS resolver and socket dialer that blocks RFC 1918 private IPs (`10.0.0.0/8`, `172.16.0.0/12`, `192.168.0.0/16`), loopback (`127.0.0.0/8`), link-local/cloud metadata (`169.254.169.254`), and IPv6 equivalents on **every** DNS resolution and HTTP redirect hop.	OWASP SSRF Prevention Cheat Sheet
ASN.1 & Image Parser Exploits	Enforce strict payload caps (max 10 MB HTTP body, max 5 redirects, max 64 KB X.509 chain) and implement X.509 ASN.1/DER parsers and image decoders in memory-safe languages (Rust or Go) to eliminate heap overflows and zip bombs.	RFC 5280 ASN.1 Profile
Stored XSS in Analyst Portal	Defang all stored URLs (`hxxps://`) in logs, strip executable scripts from captured DOM trees, and serve screenshots/HTML artifacts from a separate cookieless domain with `Content-Security-Policy: sandbox` and `X-Content-Type-Options: nosniff`.	OWASP CSP Cheat Sheet
Threat Feed Poisoning	Authenticate TAXII 2.1 clients via mTLS client certificates or vault-rotated API keys, require cryptographic signatures on ingested STIX bundles, and maintain a protected canary allowlist of verified banking, university, and government domains that cannot be auto-blocked without human sign-off.	CISA OASIS STIX 2.1 Best Practice Guide
Tenant Privacy & Egress Cloaking	Provide a "Private Scan" mode that HMAC-hashes submitted URLs and encrypts artifacts under tenant-specific KMS keys; route outbound probes through decoupled, rotating egress proxies so attackers cannot fingerprint or block your scanner IPs.	OWASP Testing for SSRF